

Review

Review of eXplainable artificial intelligence for cybersecurity systems

Stéphane Reynaud¹  · Ana Roxin¹ 

Received: 15 January 2025 / Accepted: 14 May 2025

Published online: 27 May 2025

© The Author(s) 2025 

Abstract

This article reviews approaches based on artificial intelligence (AI), which contributes to the security of cyber environments. We examine existing techniques using several indicators: explainability, performance and robustness. These indicators have been chosen based on their importance for user acceptance and interpretability of the approach. Indeed, the AI field is vast and is divided into several sub-domains. The two most well-known sub-domains are symbolic AI (representation of knowledge, rules and operations based on symbols) and numeric AI (calculations and algorithms using numeric information, focusing on the result, not the representation of knowledge). While most approaches investigated come from numeric AI, we conclude on the need for hybrid AI systems, combining the advantages of both AI sub-fields while maximising the protection provided against cyberattacks.

Keywords Artificial intelligence (AI) · eXplainable AI (XAI) · Cybersecurity · Explainability · Transparency · Justifiability · Interpretability · Suitability · Accuracy · Precision

Abbreviations

AE	Autoencoder, a type of neural network used for unsupervised learning tasks such as dimensionality reduction and anomaly detection
AI	Artificial intelligence is a field of computer science that involves developing algorithms and models that can perform tasks that would typically require human intelligence, such as perception, reasoning, and decision-making
AUC	Area Under the Receiver Operating Characteristic Curve, a metric used to evaluate the performance of binary classification models. It represents the probability that a randomly chosen positive instance will be ranked higher than a randomly chosen negative instance
Bi-LSTM	Bidirectional Long Short-Term Memory, a recurrent neural network used for sequence-to-sequence tasks such as natural language processing. It's a variation of LSTM, which processes the input sequence in both directions, with separate hidden states for the forward and backward passes
CIA	Confidentiality, Integrity, Availability
CNN	Convolutional Neural Network, a deep learning algorithm for image and video analysis tasks
CPS	Cyber-Physical Systems, a system of collaborating computational elements controlling physical entities
DDoS	Distributed Denial of Service, a type of cyberattack that aims to make a website or network unavailable by overwhelming it with traffic from multiple sources
DGA	Domain Generation Algorithm, a technique malware uses to generate many domain names for command and control (C2) communication or for hosting malicious content

✉ Stéphane Reynaud, stephane_reynaud@etu.u-bourgogne.fr; ✉ Ana Roxin, ana-maria.roxin@u-bourgogne.fr | ¹LIB (Laboratoire Informatique de Bourgogne) UR7534, Université Bourgogne Europe, Dijon, France.



DL	Deep Learning, a subset of machine learning that involves using neural networks with multiple layers to learn data representations
DNN	Deep Neural Network, another term for a deep learning model
DoS	Denial of Service, a type of cyberattack that aims to make a website or network unavailable by overwhelming traffic from a single source
DT	Decision Tree, an algorithm for supervised learning tasks such as classification and regression
EBM	Explainable Boosting Machine, an algorithm that generates human-understandable explanations of the model's decision-making process
EU	European Union
FN	False Negative, a type of error occurring when a model fails to detect a positive case (e.g., a malicious file)
FP	False Positive, a type of error that occurs when a model incorrectly identifies a negative case (e.g., a benign file) as positive
FPGA	Field Programmable Gate Array, a highly customisable and reconfigurable integrated circuit that can be programmed and configured by a user or designer after manufacturing
GDPR	General Data Protection Regulations
GNN	Graph Neural Network, a deep learning algorithm for analysing graph-structured data
Grad-CAM	Gradient-weighted Class Activation Mapping, a technique used to generate heatmaps that highlight regions of an image that contributed most to a neural network's classification decision
GRU	Gated Recurrent Unit, a recurrent neural network used for sequence-to-sequence tasks such as natural language processing and time series analysis
HIPAA	Health Insurance Portability and Accountability Act
IDS	Intrusion detection system
LIME	Local interpretable model-agnostic explanations, a technique used to explain the predictions of black-box models by approximating them with an interpretable model
LSTM	Long short-term memory, a recurrent neural network used for sequence-to-sequence tasks such as natural language processing and time series analysis
ML	Machine learning, a type of artificial intelligence that involves training models to make predictions or decisions based on data
NN	Neural network, a machine learning algorithm inspired by the structure of the human brain
ResNet	Residual Network is a deep learning architecture that allows for training very deep neural networks with thousands of layers while avoiding the problem of vanishing gradients
RF	Random Forest, an ensemble learning method that uses multiple decision trees to make predictions
RNN	Recurrent Neural Network, a neural network used for sequence-to-sequence tasks such as natural language processing and time series analysis
SHAP	SHapley Additive exPlanations, a technique used to explain the predictions of machine learning models by attributing a value to each feature
SVM	Support Vector Machine, a algorithm used for supervised learning tasks such as classification and regression
t-SNE	T-Distributed Stochastic Neighbour Embedding, a technique for visualising high-dimensional data in two or three dimensions
XAI	EXplainable Artificial Intelligence, a field of AI on developing AI systems that can explain themselves in a way that humans can understand
XGBoost	EXtreme Gradient Boosting is an open source, distributed gradient boosting library designed for efficient and scalable implementation of gradient boosting and used for improving the performance and accuracy of machine learning models, specifically in classification and regression problems

1 Introduction

The Internet has dramatically expanded the scope of the cyber environment by increasing the number of interconnected devices, e.g., the Internet of Things (IoT) and wireless (sensor) networks. In addition to traditional computing devices, applications, systems, and services, the cyber environment now includes data and software stored on removable media and

transmitted over various types of networks, as well as the people who use these devices and networks and the physical structures hosting them [1].

Not a day goes by without news demonstrating the vulnerability of today's IT systems and applications. The number of attacks and data breaches is on the rise [2], while attacks are becoming increasingly precise and sophisticated. Additionally, the expansion of cloud computing usage depicts a new threat landscape; in France, attacks on the cloud have increased by 630% in 2020 compared to 2019 [3]. Each wrongly configured cloud identity becomes an opportunity for attackers, and privileged access is aimed by almost all advanced attacks [4].

While some things may appear obvious, such as the need to protect enterprises' operational parts, not all threats are always well identified in this highly evolving landscape. Most requirements and regulations are known to human users, such as business leaders' legal obligations and responsibilities in the operation and control of their IT. Implementing system protection in the form of a security policy becomes mandatory. It encompasses developing procedures, defining the actions to be undertaken and the persons responsible, determining the concerned data in electronic and paper form (files, messages, etc.), network transactions, software applications and databases, not to mention service continuity and disaster recovery plans.

Cybersecurity is a subset of information security that protects electronic data and information. Cybersecurity considers security at an organisational level and at all levels (including physical security). Cybersecurity protects devices, networks, and sensitive information from unauthorised access, use, disclosure, disruption, modification, or destruction.

When considering cybersecurity in a vast and complex environment, one must encompass dimensions and axes beyond network security of the online world, integrating data and physical security. In cybersecurity, security is evaluated through three fronts: confidentiality, integrity, and availability (also known as the CIA triad). For a specific organisation or context, the emphasis on these factors may differ, thus resulting in different choices regarding security and privacy tools and implementations. For example, in the case of an organisation that considers confidentiality to be of the highest importance, access control and encryption would be more enforced than in the case of an organisation that focuses on data availability. Traditional approaches to cybersecurity include log monitoring, network scans, and intrusion detection systems [5]. These methods rely on pre-defined rules and patterns to identify and alert potential security threats. However, these methods can be ineffective due to the volume and complexity of data and the evolving nature of cyber threats.

AI is increasingly used in cybersecurity to address these limitations. AI-based approaches can analyse vast amounts of data in real-time and identify patterns and anomalies that may indicate a security threat. This allows for more accurate and efficient threat detection and response. Additionally, AI-based systems can be continually trained and updated to adapt to new threats, making them more resilient to the evolving nature of cyber-attacks [6].

Indeed, AI-based approaches have the potential to significantly enhance the effectiveness of cybersecurity measures and help organisations better protect against cyber threats. However, using AI in cybersecurity raises legitimate concerns, such as the potential for bias and the need for explainable AI (XAI) [7].

The two most well-known sub-domains are symbolic AI (representation of knowledge, rules and operations based on symbols) and numeric AI (calculations and algorithms using numeric information, focusing on the result and not on the representation of knowledge) [8].

These two branches of AI are further defined in section 1, along with an overview of cybersecurity, including a list of the most typical cyberattack categories. Section 2 details the selected approach to comb through the literature about AI for cybersecurity. A review of the most relevant state-of-the-art approaches is given in section 3 for these four categories: network security, endpoint security, application security and user security. The findings are analysed in section 4. Section 5 concludes this article and provides future directions.

2 Related background

While no single theoretical framework currently encompasses all the concepts, techniques, constructs, and technologies within the field of AI, the standard AI foundations allow the creation of hybrid systems using a combination of different AI methods. This enables the modelling of cognitive phenomena and the development of intelligent systems in a flexible, efficient, and robust fashion. [9].

2.1 Symbolic AI definition

Symbolic AI, also known as "classical AI", is a branch of AI that has its roots in the early days of AI research. For some, it goes back in 1958 to John McCarthy's idea of using logic to represent data and information a computer program must handle [10]. For others, it is associated with Newell's and Simon's hypothesis of a "physical, symbolic system" [11]. They believed intelligence can be modelled and represented symbolically, using explicit rules and symbols. The methods belonging to the category of symbolic AI have three core assumptions [8]:

1. A model representing an intelligent system can be defined explicitly, comprising clear, explicit rules and representations.
2. In such a model, knowledge is represented symbolically, using a formal language or notation that a computer can manipulate and process.
3. Mental or cognitive operations are formal operations over symbolic expressions and structures of a knowledge model.

Symbolic AI is often associated with expert systems, which use a knowledge base of facts and entailment rules to solve problems in a specific domain. It focuses on knowledge representation and rule-based reasoning. The systems are easy to understand and explain, but they have some limitations, mainly in handling uncertainty, incomplete data, ambiguity, and reasoning over vast amounts of data.

2.2 Numeric AI definition

Numeric AI, also known as "Statistical AI" or "Computational AI", is a branch of AI that goes against the core assumptions behind symbolic AI. The central hypothesis is that human reasoning is too complex to be modelled using symbols. Numeric AI emphasises numeric computation and data-driven approaches to model problem-solving. Numeric AI is a set of techniques and methodologies that allows knowledge extraction from data using mathematical methods and computation, and it's mainly focused on the quantitative analysis and representation of knowledge.

The methods belonging to the category of numeric AI have three core features [8]:

1. Numeric information is essential in a knowledge representation, meaning that the information used to model an intelligent system is typically represented in terms of numbers and measurements, such as probabilities or likelihoods.
2. Knowledge processing is based mainly on numeric computation, meaning that mathematical methods, such as optimisation algorithms and machine learning (ML) techniques, are used to process and analyse the data.
3. Knowledge is not represented explicitly, meaning that it is not represented using symbols or rules, but rather, using patterns and relationships in the data.

For the sake of clarity, we list the following methods as belonging to numeric AI, even though they may not fully adhere to the defined characteristics above [8]: (artificial) neural networks, pattern recognition, cluster analysis, Bayesian inference, models based on fuzzy sets, models based on rough sets, evolutionary computing (genetic algorithms, evolution strategies, evolutionary programming, and genetic programming), swarm intelligence, artificial immune systems.

2.3 Cybersecurity domain

Cybersecurity is the approach and actions associated with security risk management processes followed by organisations and states to protect the confidentiality, integrity, and availability of data and assets used in cyberspace [5]. This concise definition of cybersecurity covers the collection of artefacts ranging from tools, policies, security concepts, security safeguards, guidelines, and technological infrastructure to processes, assurances, measures, best practices, and training.

Confidentiality is the first of the three objectives. In the context of this paper, it refers to protecting sensitive information from unauthorised access or disclosure. Enabling confidentiality relies on implementing security controls to avoid unauthorised disclosure. Among those, we may cite encryption, access controls, and other security technologies

and procedures for safeguarding sensitive data and preventing it from falling into the wrong hands. Confidentiality is essential to cybersecurity because it helps prevent sensitive information from being used maliciously, such as in identity theft, fraud, or other cybercrimes. Additionally, organisations must maintain their data's confidentiality to comply with regulations, laws, and industry standards. Especially regarding international laws and regulations, confidentiality is enforced in the EU through the GDPR (General Data Protection Regulations), articles 5, "Principles relating to processing of personal data" and 25 "Data Protection by design and by default", in the US through the Privacy Act from HIPAA (Health Insurance Portability and Accountability Act), or in Canada through section 63 of the Canadian Privacy Act.

Additionally, experts also recommend ensuring data integrity. Integrity refers to the assurance that data has not been altered, tampered with, or corrupted in any unauthorised or undetected way. Following McBride et al. [12], generic means for enabling integrity include corruption testing, secure storage, backup capability and logging, for example, through security incident and event monitoring (SIEM) applications and network data capture systems. Integrity security controls also assure nonrepudiation, which means that the sender of the data cannot later deny having sent it. Ensuring the authentication of the sender or the receiver prevents user impersonation. Integrity in cybersecurity is about maintaining the trustworthiness of data and ensuring that it is accurate and reliable. Integrity is especially critical in some domains. For example, data integrity directly impacts patient care and safety in healthcare, as using altered or non-accurate patient data can lead to death. EU GDPR states in article 5 that "1. Personal data should be: [...] processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality')".

While data can be private and accurate, it is not valuable if it cannot be timely accessed. Following ITU-T [1], general security objectives comprise availability, which refers to the ability of a system or network to be accessible and usable by authorised users when they need it. This includes ensuring that the system is running without interruption, that data and resources are accessible to users, and that any necessary services or functions are functioning correctly. It also implies that the system can sustain a certain level of workload and can manage and recover from potential failures, malicious attacks, natural disasters, or other incidents that might disrupt its regular operation. It is crucial to ensure that critical business processes can continue while the system can provide reliable services to its users. Additionally, international laws and regulations such as GDPR and HIPAA further state that only the necessary information should be available. For example, article 5 in EU GDPR states that "1. Personal data should be: [...] adequate, relevant and limited to what is necessary concerning the purposes for which they are processed ('data minimisation')".

Often called the 4th cybersecurity principle, accountability refers to the possibility of determining who is responsible for information access and use, be it proper or improper. Accountability represents the intersection of the CIA principles: when accessing or entering data, an individual should ensure its integrity and confidentiality and leverage the system's availability. According to existing compliance standards, accountability is considered a fundamental principle. For example, EU GDPR article 5 states, "2. The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability')". Additionally, recital 85 in EU GDPR states that "as soon as the controller becomes aware that a personal data breach has occurred, the controller should notify the personal data breach to the supervisory authority without undue delay and, where feasible, not later than 72 h after having become aware of it, unless the controller can demonstrate, following the accountability principle, that the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons." An organisation must thus be able to demonstrate responsibility for the data and information it collects, stores and uses. Accountability includes tracking actions, e.g. logs and audits, and identifying responsible parties retrospectively after a cybersecurity incident or a data breach. Nonrepudiation is an essential aspect of accountability, which helps organisations provide evidence of their accountability. With specific regard to accountability, explainability is crucial when using AI for cybersecurity (as discussed in Sect. 2A).

Finally, cyberattacks can be divided into different categories. According to Srivastava, et al. [7], most typical cyberattacks can be categorised as follows (Table 1):

Regardless of the type of attack, they all exploit some vulnerability, meaning a breach in the assets, the technical security controls, and operating or administrative procedures used in a given organisation. Following Hylander, et al. [2], most breaches (74%) involve humans through errors, use of stolen credentials, privilege misuse or social engineering. In 2023, ransomware is the number one action perpetrated by attackers, representing 24% of actions [2].

Table 1 Typical cyberattacks [7]

Cyberattack	Description
Malware	Malware is a type of malicious software that is designed to harm a computer or network. Examples of malware include viruses, spyware, and ransomware. Once a device is infected with malware, the attacker can gain unauthorised access to the device and its associated networks, data, and applications. This can lead to data being stolen, resources being blocked, and the device being completely disabled
Social engineering	Social engineering attacks are a type of cyberattack that relies on tricking people into giving away sensitive information or access to resources. Phishing is a common type of social engineering attack, where an attacker sends an email or message that appears to be from a trusted source, such as a bank or well-known company and asks for sensitive information or login credentials. These attacks aim to gain fraudulently unauthorised access to sensitive information
Man-in-the-middle	A man-in-the-middle attack is a cyberattack where an attacker intercepts and alters the communications between two parties. The attacker intercepts the communications and alters them without the parties realising it, thereby gaining unauthorised access to sensitive information. The attacker can also provide false information to the parties, which would be perceived as legitimate
Denial-of-service (DoS)	A denial-of-service attack is a type of cyberattack where a system is overwhelmed with fraudulent requests, which causes it to stop working correctly or become unavailable. This can prevent legitimate users from accessing the system. In a Distributed Denial of Service (DDoS) attack, multiple attackers launch the attack simultaneously, amplifying the attack's impact
SQL injection	An SQL injection attack is a cyberattack involving injecting malicious code into a back-end database. The attacker can use this to gain unauthorised access to protected data, steal data, and execute arbitrary code
Zero-day attack	A zero-day attack is a cyberattack that takes advantage of a previously unknown security vulnerability. These attacks are hazardous because they can be launched before a security patch is available
Evasion attack	An evasion attack targets the input data of an existing model to evade or bypass the system or system's protection implemented by this model
Poisoning attack	A poisoning attack is an attack that targets the training data of a model by adding or manipulating the input data with malicious intent to cause the model to produce incorrect or malicious outputs
Malware	Malware is a type of malicious software that is designed to harm a computer or network. Malware examples include viruses, spyware, and ransomware. Once a device is infected with malware, the attacker can gain unauthorised access to the device and its associated networks, data, and applications. This can lead to data being stolen, resources being blocked, and the device being completely disabled

3 AI for cybersecurity

Cybersecurity is a rapidly evolving field with an ever-increasing number of threats. The volume and complexity of these threats make it difficult for human operators to keep up with the sheer number of security incidents that need to be investigated. Organisations try to address this problem by using algorithms to improve the efficiency of the threat triage process. This involves using automated systems to perform an initial screening of security incidents so that only the most severe threats are passed on to human analysts for further investigation.

Using algorithms can significantly improve the speed and accuracy of threat triage, allowing security teams to identify and respond to potential threats quickly. However, algorithms alone may not be sufficient to keep pace with the rapidly evolving threat landscape.

AI is increasingly being used to augment the capabilities of cybersecurity professionals. AI-based systems can analyse large amounts of data and identify patterns humans might miss. This enables organisations to detect and respond to threats more quickly and effectively. There are three tasks where AI proves highly effective, especially compared to non-AI algorithms [6].

First, classification involves assigning a label or category to a given input based on pre-defined classes or categories. In identifying different types of attacks, such as malware or malicious information like spam, classification involves analysing the input features (e.g., the code or content of a file or message) and comparing them to the characteristics of known attack types. The input is then assigned the label of the class or category that it most closely matches.

Then clustering consists of grouping similar objects or data points based on their characteristics or features. When grouping similar assets, clustering algorithms analyse each asset's features and assign them to groups or clusters such that the assets within a cluster are more like each other than those in different clusters. Clustering is particularly useful

when the classes the assets belong to are unknown, like in forensic analysis, where the objective is to discover structure in the data rather than predict a class label.

Third, prediction uses a model to forecast or estimate future events or outcomes based on historical data or information. When identifying threats and attacks, prediction involves historical data or information, such as past attacks, to learn patterns and relationships indicative of future attacks. This can allow for early detection and response, which can minimise the impact of the attack and prevent further damage.

Furthermore, effective management of AI-based cybersecurity tools and systems requires technical skills and a deep understanding of these tools' underlying logic and workings. Cybersecurity professionals need to understand the algorithms, models, and data used by AI systems and be able to interpret the results generated by these systems.

Additionally, being able to understand the logic of the AI systems involved in cybersecurity is critical to being able to improve these tools and systems. This means identifying areas where the system may be producing inaccurate results or could be improved in terms of performance. It also means identifying potential biases or weaknesses in the system that attackers could exploit.

This level of understanding allows cybersecurity professionals to make informed decisions about configuring and using these tools and identify improvement opportunities. They can then work with the development team to adjust or fine-tune the systems or suggest new features to make the system more effective. Furthermore, knowing the internal AI system helps understand decision points, uncertainty, and potential false positives/negatives.

Moreover, cybersecurity professionals must stay current with the latest developments in AI research, both in terms of new techniques and algorithms, as well as advances in related fields such as ML and natural language processing. This helps them understand the capabilities and limitations of the tools they are using and identify new opportunities for how these tools can improve cybersecurity.

3.1 Explainability

Even though *explainability* is not a new concept in AI, there is still a lack of consensus over defining precisely what explainability entails. Therefore, the approach has been to keep high-level definitions of features commonly found in the literature despite some differences in terminology or coverage. Most authors use "explainability" and "interpretability" as synonyms. In the next paragraphs, we provide some of the most precise definitions we found for these two concepts.

DARPA defines explainable AI as an AI system capable of explaining its reasoning to a human user, characterising its strengths and weaknesses while providing insights into it will behave in the future [13]. Following Ciatto et al. [14], explainability is the production of a more interpretable object from a less interpretable one. Gunning et al. [13] consider an explanation in a context depending on the task, capabilities, and expectations of the AI system's user. They view explanations as complete or partial. Their definitions of interpretability and explainability are domain dependent. Miller [15] defines "explanation" as the answer to a question such as what, how, or why. An answer to a "what" question is a factual account of events. An answer to a "how" question indicates the causes of an event. An answer to a "why" question is counterfactual because it requires explaining why other events did not occur. Authors consider this to be the most complex type of answer to produce. In [15] truly explainable AI models can provide contextual explanations. For example, while an event may have multiple causes, the recipient of the explanation may only be interested in a small subset of causes (relevant to a specific context); the AI system must be able to provide such an explanation, bounded to the contextual causes selected. Gilpin et al. [16], suggest a more restricted definition for an explanation, limiting it to "why" questions. They add that an explanation can be interpretable and exhaustive (completeness). The latter refers to the precise description of an AI system's operations. Authors also define "interpretability" as a description of the internal functioning of an AI system, in a way that is understandable for humans. The descriptions produced by such a system are simple enough to be understood by a person and use a vocabulary that makes sense to this person. A difficult task is to have an explanation that is both interpretable and exhaustive.

Interpretability is closely related to the concepts of comprehensibility and understandability. It's about explaining the system's actions and decisions in a way easily understood by a human audience, depending on their level of understanding and expectations of the field [17]. Several definitions of "interpretability" are found in literature. According to Brian and Cotton, [18], systems are interpretable if their operations can be understood by a human being, either through introspection or through a produced explanation. Montavon et al. [19] define "interpretability" as mapping an abstract concept into a domain that humans can understand. For Calegari et al. [20], "interpretability" is a subjective relationship

associating a representation with a specific meaning in the problem domain. Ciatto et al. [14] define it as assigning subjective meaning to an object, done by a (human or non-human) agent, with little computational or cognitive effort.

In the context of this article, we adhere to the position argued by Russell and Norvig [21], stating that explainability is built upon interpretability. Interpretability addresses the issue of understanding why an AI system produced a given output, given a specific input. It relates to understanding the causes and the effects of an AI system. An AI system is said to be interpretable if one can examine the model and "why it got a particular answer for a given input, and how the answer would change if the input changed". Examples of interpretable AI models are decision trees or linear regression models. Explainability goes beyond interpretability and provides a human-readable way of explaining how and why a model produces a given output. Following [21], while the inspection of the model provides interpretability, explainability is a separate process summarising what the model does. LIME¹ (Local Interpretable Model Agnostic Explanations) is an example of such a separate explanation module [22]. Whatever model is used, LIME creates an interpretable approximation of it in the form of a linear model, which provides explanations of each feature's importance.

An AI system is considered comprehensible to humans when it can explain and provide the meaning or represent the knowledge learned in terms understandable for a human [23]. This means the explanations must be relevant and understandable for the specific people for whom the system is designed. For instance, the explanations provided to a non-technical audience may differ from those provided to a technical audience in detail and technicality. In the context of AI systems, there is a trade-off to be considered between models providing simple explanations and models with higher accuracy. Trust and confidence are two related underlying concepts, and explanations are insufficient to reach trust. As explained by [21], an explanation is "a story" about decisions made by the system considered. Simple explanations may be too appealing and fail to cover all underlying causes leading to the considered output. While a system is said "interpretable" if one can examine its source code and its functioning, it is said "explainable" if it can provide explanations (stories about what it's doing), even if it is an "uninterpretable black box" [21]. Explainable AI is the field of AI that focuses on creating systems that are transparent and interpretable [23].

When considering decision-making and society, one essential aspect of AI is allowing transparency and justifiability. These non-fully independent features allow for the definition of complementary requirements that an AI system needs to meet, at least partially, to be qualified as being explainable to some degree. We discuss them below.

- Transparency

An AI system is said to be transparent if it can be easily understood and described by humans without the need for extensive technical knowledge or detailed explanations of the internal processes and structure of the system. A transparent AI system is one that a human can easily understand without additional information or explanation [23]. One aspect of transparency is allowing users to know whether they are interacting with an AI system or a human [24].

- Justifiability

An AI system is justifiable if it can provide a rationale for its decisions. This means that the system should be able to expose the reasoning behind its decisions and the knowledge it used to reach them in a way that is comprehensible to humans by providing enough information for a human to understand why a decision was made [25], regardless of whether the decision itself is easy to understand. It requires the system to demonstrate the justification, or evidence, of its decision; it could be in logical reasoning, data, or any other evidence supporting it. No specific quality metric is imposed on the justification; it only needs to be enabled for the justifiability feature to be considered [17].

Following previous considerations, we adhere to the definition provided by [21] for a "good explanation": "it should be understandable and convincing to the user, it should accurately reflect the reasoning of the system, it should be complete, and it should be specific in that different users with different conditions or different outcomes should get different explanations."

Given the high stakes involved, cybersecurity professionals must be able to trust and understand an AI system's output, particularly considering emerging regulatory and audit requirements. Indeed, initiatives such as the Artificial Intelligence Act (AIA [26]) increasingly demand that AI-driven decisions be explainable, highlighting the need for both

¹ LIME: Local Interpretable Model-agnostic Explanations, a technique used to explain the predictions of black-box models by approximating them with linear (thus interpretable) models.

qualitative and quantitative methods to measure explainability. Qualitative methods focus on user studies or interviews with cybersecurity experts to assess whether the system's explanations are actionable or sufficiently understandable for human operators. Quantitative methods often examine fidelity metrics (e.g. how well LIME or SHAP² [27] approximations align with the original model's predictions) or evaluate complexity-based criteria (e.g., the number of rules in a post-hoc decision tree or the number of features used in an explainer). A recent 2023 benchmark study by Rida et al. [28] compared four models on the CIC-IDS2017 dataset. Three relevant metrics were tracked: accuracy, the time to generate explanations, and the "Top-5 Feature Consensus" (i.e., how consistently a model's top five most influential features remained the same across multiple explanation runs). The highest accuracy (98.2%) was achieved at the cost of significantly longer explanation times, whereas inherently transparent decision rules yielded higher explanation stability (91% vs. 83% consensus). The benchmark also introduced an "Action Window" threshold (≥ 1.5 s) to ensure analysts can promptly validate or respond to alerts. These key findings demonstrate the trade-off between detection performance and timely, high-fidelity explanations, underscoring that explainability must be both accurate and rapid enough to be actionable in real-world cybersecurity contexts.

3.2 Performance

3.2.1 Suitability

When evaluating the performance of AI systems, quality performance measures are used to assess the system's capabilities and performance, and they can be evaluated or approximated even in the absence of real-world implementation and/or data. This allows for assessing a system's potential performance before deploying it in the real world.

Moreover, no established framework exists for quantitative measures of heterogeneous AI approaches, such as symbolic or numeric AI. This makes it challenging to compare and evaluate the performance of different AI systems, as no consistent set of metrics can be applied across different implementations and their associated datasets.

ISO/IEC TS 25011 provides the below table of quality characteristics for IT services [29] (Table 2):

In the context of this article and the publications found, one characteristic from Table 1 identified as crucial and measurable is suitability. Suitability means the system meets stated and implied needs when used in the specified context [29]. Suitability ensures completeness (the system supports all the defined goals, objectives, and data), correctness (the system produces correct results with accurate data through a proper process), appropriateness (the results produced by the system are appropriate relative to the user's needs), and consistency (the quality of the system is consistent across repeated use).

3.3 Accuracy and precision

The lack of a consistent set of quantitative metrics makes it difficult to compare the performance of different AI systems and to evaluate the strengths and weaknesses of various approaches. Therefore, to determine the overall performance of heterogeneous AI systems and identify the areas where they are performing well or poorly, the quantitative measures the most encountered in the literature are accuracy and precision.

ISO 5725-1 [30] provides its definition of "accuracy" being the composite of "trueness" and "precision". These two terms are defined as follows:

- "Trueness: The closeness of agreement between the average value obtained from an extensive series of test results and an accepted reference value.
- Precision: The closeness of agreement between independent test results obtained under stipulated conditions."

The above definition of "trueness" corresponds to the everyday use of "accuracy" in AI literature. Thus, in the context of this paper, we keep "accuracy" as the term of choice.

In other and more detailed terms:

² SHAP: SHapley Additive exPlanations, a technique used to explain the predictions of machine learning models by attributing a value to each feature.

Table 2 Quality characteristics for IT services [29]

Dimension	Quality characteristics
IT service adaptability	Customisability
IT service maintainability	Initiative
	Analysability
	Modifiability
	Testability
IT service reliability	Continuity
	IT service recoverability
	Availability
Responsiveness	Timeliness
	Reactiveness
Security	Confidentiality
	Integrity
	Traceability
Suitability	Completeness
	Correctness
	Appropriateness
	Consistency
Tangibility	Visibility
	Professionalism
	IT service interface appearance
Usability	Appropriateness recognizability
	Learnability
	Operability
	User error protection
	Accessibility
	Courtesy
	Appropriateness recognizability

- A measurement method's accuracy ("trueness") is essential when the measured property has a known or accepted true value. Even if this actual value cannot be determined precisely, a reference value may be established using reference materials or by comparison to another measurement method. "Trueness" can be evaluated by comparing the reference value to the results obtained from the measurement method. This is typically expressed as bias, which can occur due to factors such as incomplete extraction of an element or interference from other elements during analysis.
- Precision refers to the variability between repeated measurements. Two types of precision, known as repeatability and reproducibility, are often used to describe the variability of a measurement method. Repeatability conditions assume that contextual factors (the operator, the equipment, the time elapsed between measurements, or environment characteristics like temperature and humidity) do not affect the variability. In contrast, reproducibility conditions consider that these factors may contribute to the variability of the results. Repeatability represents the minimum variability, and reproducibility represents the maximum variability. Precision is typically measured in terms of standard deviations.

As one may suspect, in a cybersecurity context, an AI system's accuracy and precision deeply impact its defensive capabilities, namely effective threat detection, risk management or incident response. Regarding threat detection, accuracy and precision bring an improved complex pattern and anomaly recognition [31], through higher detection rates (ranging from 80 to 92% and surpassing more than 50% the rates achieved by traditional signature-based malware systems [32] and a reduced number of false positives, thus reducing alert fatigue for security teams which can focus on real threats instead [33].

3.4 Robustness

AI robustness refers to the ability of an AI system to maintain its intended behaviour in the face of unexpected changes or perturbations in the environment in which it operates. These changes may be natural, such as drifts in the input data, or malicious, such as an adversary trying to gain unauthorised access to the system.

For an AI system to be robust, it must continue functioning safely and effectively even when faced with these unexpected changes. It means that the system should be able to adapt to new circumstances and maintain its intended behaviour without failure or compromise.

When dealing with system quality, robustness is closely related to "context coverage" [34], which measures how well an AI system can handle changes in the operating context. Context coverage is distinct from context completeness (defined simply as *completeness* in section II.B), which refers to the completeness of the information provided to the AI system, but it focuses on the ability of the system to handle unforeseen changes in input.

Three identified types of changes may challenge the robustness of an AI system [34] and are discussed below.

- Distributional change refers to changes in the input distribution over time, which can affect the behaviour of an AI system. It is a common challenge facing AI systems and related to the concept of generalisation in AI. Maintaining the system behaviour as the input distribution shifts over time is crucial to ensure the robustness of an AI system.
- Adversarial inputs are another type of challenge that an AI system may face. Unlike natural changes, these inputs have been manufactured by a malicious adversary to lead the AI system towards failure. An adversarial input is designed to manipulate the system's behaviour and cause it to produce incorrect results.
- Maintaining explainability relates to changes in the input distribution, whether malicious or natural, which can lead to unexpected results that may not be easy to understand. Explainability can be used to detect whether an adversarial attack is the cause of that change. It allows an understanding of the decisions and actions of an AI system and helps detect any unexpected or anomalous behaviour that adversarial inputs may cause.

Concerning cybersecurity, a robust AI system presents several benefits but also comes with several challenges that need to be addressed, such as the expansion of attack surfaces, the potential for hiding malicious activities or making harmful decisions if compromised or the potential for developing malware capable of adapting to prevent detection by existing security systems [35]. In parallel, a robust AI system can improve an organisation's defensive capabilities [36] by providing a shield against adversarial attacks and preventing the AI system from being compromised or misled, more specifically, from a regulatory point of view, under the AIA [26], while the concepts "cybersecurity" and "robustness" appear related (i.e. Article 15 "Accuracy, Robustness and Cybersecurity" in the AIA) as they both address an AI system's resilience to performance disruptions or attacks [37]. But "robustness" is defined as an AI system's ability to be "resilient in relation to harmful or otherwise undesirable behaviour that may result from limitations within the systems or the environment in which the systems operate (e.g. errors, faults, inconsistencies, unexpected situations)". Addressing the above-mentioned challenges when designing AI systems is also enforced in the EU AIA, and specific solutions such as fail-safe plans are listed.

4 State of the art of the most relevant approaches

As identified by Parisi [6], four large cybersecurity domains are well-suited for AI-based systems. We present them below.

Network security protects a computer network and its associated infrastructure from unauthorised access, use, disclosure, disruption, modification, or destruction. It can include protection at all layers of the network stack, from the physical infrastructure and devices to the network itself to the applications and services that run on top of it. One of the primary concerns of network security is maintaining the integrity of the network perimeter, which refers to the logical and physical boundaries that separate a secure internal network from an untrusted external network, such as the Internet. This includes protecting against unauthorised access, intrusion, and other forms of cyberattacks that attempt to penetrate the network perimeter. Another critical aspect of network security is maintaining the availability of the network, which means ensuring that authorised users have access to the resources they need when needed. It comprises protection against DoS attacks, which attempt to flood a network with traffic to overwhelm it and prevent legitimate users from accessing it. It is also crucial to ensure the confidentiality

of transiting information and protect sensitive information from unauthorised disclosure as it flows across the network. It encompasses encrypting data flows across the network and implementing access controls to ensure only authorised users can access the information.

Endpoint security includes a set of security measures designed to protect devices used by end-users, such as computers, laptops, mobile devices, IoT devices, and portable storage devices, from various types of cyber threats. It is also known as "client security" as it protects all client devices that could connect to the network. Endpoint security includes a variety of technologies and techniques used to protect devices themselves, as well as data stored and exchanged among devices. It provides antivirus software, firewalls, intrusion detection and prevention systems, and malware scanners, which detect and block malicious software and other cyber threats. Additionally, endpoint security also includes measures that ensure the reliability and usability of the devices, such as software updates and patches that fix security vulnerabilities and improve the overall performance and stability of the device. Endpoint security also includes Device management and control, which allow IT administrators to centrally manage and monitor the security of all the endpoint devices. It comprises capabilities such as remote lock and wipe, inventory management, and deploying security policies and software across the organisation. Another essential aspect of endpoint security is to protect the devices from malicious alterations, which includes protection against firmware and BIOS-level malicious alteration and hardware-based attacks. Such attacks can consist of using digital signatures to ensure that firmware and software have not been tampered with and hardware-based security solutions like Trusted Platform Module (TPM) that provide secure storage for encryption keys.

Application security targets the protection of all applications from various types of cyber threats, independent of the device or environment on which they are running. It encompasses the security of software, web, mobile, and cloud-based applications. The primary goal of application security is to ensure that applications operate as intended and are not compromised by unauthorised access, misuse, or alteration. Application security comprises various technologies and practices used to identify and mitigate application security vulnerabilities, such as code reviews, penetration testing, and runtime application self-protection. These measures identify and fix security vulnerabilities and weaknesses in the application code before the application is deployed and in runtime. Application security also includes measures that ensure data protection on the fly and at rest. It comes with encryption and secure communication protocols, such as HTTPS, to protect data as it is transmitted over a network and measures, such as secure data storage and access controls, to protect data when it is stored on the device or in the cloud. Additionally, application security includes measures to ensure that the application performs the intended tasks, including monitoring and analysing the application logs, using an Intrusion Detection System (IDS) to detect abnormal behaviour, and using behaviour-based detection methods to identify unknown threats.

User security, or end-user security, is a set of security measures designed to protect users from various types of cyber threats and ensure that they use systems and applications safely and securely. This category focuses on the behaviour of users and their correct use of systems. It encompasses measures such as user education and awareness training, which can help educate users on identifying and avoiding common security threats, such as phishing attacks and malware, and provide them with guidance on safe online behaviour and best practices for working securely. User security also includes measures designed to shield users from malicious actors. Among those we may cite are access controls, which ensure that only authorised users have access to sensitive information and systems, and multi-factor authentication, which allows users to verify their identity before allowing them to access systems and applications. Additionally, user security also focuses on protecting users from suffering harm from any failure; measures in this category are backup, disaster recovery and incident response plans. These measures help restore the system and data to normal in case of a failure or a malicious attack.

In the following sections, we present our findings regarding how these criteria have been addressed in the approaches published. As described below, some requirements have been only partially addressed, resulting in little or no mention of those criteria in these summaries.

4.1 Network security

4.1.1 Denial of service

Amarasinghe, et al. [38] present a framework using deep neural networks (DNN) that provide users with interpretations of the DNN's predictions. They found that their framework reached an accuracy of 97.23%, with post hoc interpretations delivered along the output and a transparent model. The robustness of the system is not addressed.

A comparison among approaches for detecting DoS attacks is provided by Amor, et al. [39]. Decision Tree (DT) obtained an accuracy of 97.24% and a precision of 92.20%, while Naïve Bayes obtained 96.65% accuracy and 91.47% precision. Only the DT can explain deductions, and the system's robustness is not a focus.

4.1.2 Network intrusion

Barnard, et al. [40] proposed a two-stage pipeline for robust network intrusion detection using XGBoost³ and AE,⁴ with SHAP method for a post hoc interpretation. This model outperformed many state-of-the-art models with 93.28% of accuracy, 97.81% of recall, and 91.05% of precision.

Wali, et al. [41] used the global interpretations created by the SHAP and Random Forest (RF) joint framework to detect all forms of malicious intrusion in network traffic while improving the robustness of the RF. The produced model had an accuracy of 98.50% and a precision of 98.22%. The extensive use of the "black box" RF classifier impairs the model's transparency.

Himmelhuber, et al. [42] used a GNN⁵ that embeds a knowledge graph and files the security alerts raised by their IDS using the ad-hoc interpretation generated from the GNN and the knowledge graph. They reduced false alerts by 66% and an AUC⁶ of 84%. Interpretability is a strong focus in their work, though without transparency due to the use of "black box" GNN.

For Network Intrusion [43], DNNs, specifically convolutional neural networks (CNNs) and AEs, are widely used in detection. CNNs process multiple data arrays effectively, while AEs are suitable for semi-supervised or unsupervised learning. However, many studies on improving detection results have not sufficiently evaluated the benchmark datasets reliability, which can result in inaccuracies when detecting new attack patterns. Therefore, more current datasets must be used for more accurate performance evaluation. We may add that several approaches slightly increased quantitative metrics using SHAP while considerably improving trustworthiness.

4.2 Endpoint security

4.2.1 Malware

Naeem, et al. [44] developed a pre-trained CNN model using Inception-v3 and transfer learning to detect malware on IoT devices. They used Grad-CAM⁷ to produce heatmaps and t-SNE⁸ to evaluate feature density in the model to provide some level of interpretability. The model achieved a 98.5% detection accuracy and 96.9% precision.

Yan, et al. [45] proposed a method to extract rules from a trained DNN to produce a DT. This model is then used to identify mobile malware behaviour, which was found to have 98.55% accuracy, 97.93% precision, 98.27% recall and 98.04% F1-Score. The DT allows high level interpretations while yielding high overall performance. While the system is robust, the authors do not consider an adversarial change in data.

Iadarola, et al. [46] proposed a method for evaluating deep learning (DL) models for malware classification using image data. The technique utilises data from Grad-CAM and aims to improve the evaluation of the training phase of the models under study and provide visual information to security analysts. Robustness, especially adversarial resistance, is described as future work. The proposed model achieved a test accuracy of 97.0% and a precision of 97.2%. A limitation of their method is that mutated versions of malicious samples from the same family can evade antimalware detection.

Alani, et al. [47] proposed a new approach for detecting Android malware called PAIRED. This system is lightweight and efficient, using limited features and resource-efficient classifiers. Additionally, it provides interpretations for the 35

³ XGBoost: eXtreme Gradient Boosting, an open source, distributed gradient boosting library designed for efficient and scalable implementation of gradient boosting, used for improving the performance and accuracy of machine learning models, specifically in classification and regression problems.

⁴ AE: Autoencoder, a type of neural network used for unsupervised learning tasks such as dimensionality reduction and anomaly detection.

⁵ GNN: Graph Neural Network, a type of deep learning algorithm used for analysing graph-structured data.

⁶ AUC: Area Under the Receiver Operating Characteristic Curve, a metric used to evaluate the performance of binary classification models. It represents the probability that a randomly chosen positive instance will be ranked higher than a randomly chosen negative instance.

⁷ Grad-CAM: Gradient-weighted Class Activation Mapping, a technique used to generate heatmaps that highlight regions of an image that contributed most to a neural network's classification decision.

⁸ t-SNE: t-Distributed Stochastic Neighbour Embedding, a technique used for visualising high-dimensional data in two or three dimensions.

static features using SHAP methods. Robustness is mentioned as future work without further detail. In testing, the PAIRED system demonstrated an accuracy of 98.20%, a precision of 98.54% and a fast-processing time of 0.8206 μ s.

Kinthead, et al. [48] introduced a new method for identifying critical areas in the code of an Android app that a CNN model deemed significant for detecting malware. The CNN was shown to prioritise locations like those identified by LIME. The experiments yielded impressive results, such as accuracy of 98%, precision of 98%, recall of 98%, and an F1-Score of 97%.

Overall, for Malware [43], DL appears as a promising technology for developing new methods of detecting malware, especially for identifying unknown or "zero-day" malware. However, the final step in testing these methods is to deploy them in real-world environments, which requires significant effort and human intervention. Many research studies in this field do not include this validation step; instead, they rely on performance evaluation using pre-existing datasets. To be effectively used in the industry, it is essential not to overlook the importance of trial deployments in real-world settings.

4.2.2 Cyber-physical system (CPS)

For CPS [43], the time-series nature of measures in Industrial Control Systems makes LSTM⁹-based models the most efficient. The widespread False Data Injection in the Smart Grid involves using AEs and/or LTSM-based models. In Intelligent Transportation Systems, attacks on the Controller Area Network (CAN) bus system are the most frequent, so CNN and LTSM are used to capture both context information and time relations. DNN coupled with attention mechanisms can improve existing DL models by focusing automatically on the most important features.

4.3 Application security

4.3.1 Botnets

Kundu, et al. [49] proposed a one-dimension CNN botnet detection model that outperformed the existing ML models, with an accuracy between 92.14% and 97.90% and a precision between 97.50% and 99.85%. They used SHAP to explain the model decision, showing the contribution of each feature to the classification results, but their system is not transparent.

Suryotrisongko, et al. [50] used five ML algorithms tested on datasets of 55 botnet families. RF achieved the best accuracy of 96.3%, though the authors have shared no other metrics. SHAP and LIME, notably, were used to enhance the system trust through a thorough post hoc interpretability.

Alani [51] used feature selection Recursive Feature Elimination to accurately train an ML (XGBoost) classifier, with an accuracy of 99.76% and a precision of 99.63%, plus very low False Negative (FN) and False Positive (FP) rates of 0.21% and 0.31%. SHAP is used to explain the ML model predictions.

McDermott, et al. [52] trained a Bi-LSTM,¹⁰ with a word-embedding layer in front. Their model achieved accuracy ranging from 91.95% to 99.99%, though the precision is unknown. There is no available explainability at all for the model either. The inherent capability of LTSM to adapt to long-term change provides robustness in distributional change.

Overall, for Botnets [43], Recurrent Neural Networks (RNN), like Bi-LSTM or GRU,¹¹ are the best performers, as they efficiently handle sequential, time-dependent, and high-dimensional data on a massive scale. Although, the quality of the training datasets highly impacts their performance. Interpretations are limited when available and do not impact performance, except for offline computing time.

⁹ LSTM: Long Short-Term Memory, a type of recurrent neural network used for sequence-to-sequence tasks such as natural language processing and time series analysis.

¹⁰ Bi-LSTM: Bidirectional Long Short-Term Memory, a type of recurrent neural network used for sequence-to-sequence tasks such as natural language processing. It's a variation of LSTM which processes the input sequence in both directions, with separate hidden states for the forward and backward passes.

¹¹ GRU: Gated Recurrent Unit, a type of recurrent neural network used for sequence-to-sequence tasks such as natural language processing and time series analysis.

4.3.2 Domain generation algorithm (DGA)

DGA is a technique used by malware to generate many domain names to be used for command and control (C2) communication or for hosting malicious content.

Drichel, et al. [53] proposed two ResNet¹²-based DGAs detection classifiers, one for binary classification and the other for multiclass classification, the latter achieving an improvement of nearly 5% in F1-score while requiring 30% less training time than the next best classifier. Their model obtained an accuracy score for binary classification ranging from 98.52% to 99.91%. Their model obtained the following scores for multiclass classification: 81.27% for precision, 79.65% for F1-Score and 80.31% for recall. The authors made a post hoc manual features analysis to provide some interpretations for their models. Robustness is evaluated, and good results are obtained from the binary classifiers against adversarial changes.

Drichel, et al. [54] then introduced EXPLAIN, a feature-based RF and contextless DGAs multiclass classification framework, which was the best model after the ResNet-based one, outperforming models based on RNN, CNN, Support Vector Machine (SVM), RF, and all DL-based models in terms of F1 score. Their best multiclass classifier obtained a precision of 81.63%, an F1-Score of 78.55% and a recall of 77.96%. They proposed a framework to evaluate the contribution of input features to the classification results.

Mac, et al. [55] developed a method using only the domain name and used a Bi-LSTM for their DGA multiclass classifier to obtain, on average, an AUC of 0.9967, a precision of 92.32%, an F1-Score of 92.70% and a recall of 93.09%. Robustness nor explainability are part of the author's focus, though they evaluate some self-interpretable models.

Overall, for DGA [43], like Botnets, RNN tend to be the best-performing models, and their sensitivity to data quality encourages the use of more up-to-date DGA datasets like UMUDGA (University of Murcia Domain Generation Algorithm). Explainability is limited to feature selection at best.

4.4 User security

4.4.1 Fraud

Rao, et al. [56] presented xFraud, an "explainable" (i.e. interpretable) fraud transaction prediction framework with a detector and an explainer. They proposed and tested a heterogeneous GNN model for transaction fraud detection on industrial-scale datasets that outperformed previous models and captured heterogeneity in transaction graphs. The explainer in xFraud uses a combination of the weights learned by the GNN Explainer and edge weights calculated using centrality measures to compute a hybrid explainer. Their model achieved an accuracy of 97.03% with a precision of 96.13% and an AUC of 90.74%. Regarding robustness, distributional change over time is their sole focus.

Roshan, et al. [57] proposed using explainable AI methods to improve the performance of fraud detection models based on AEs with SHAP for feature selection. The model achieved an overall accuracy of 96.9%, a precision of 83% and an AUC of 94%. The top 30 features with the highest SHAP values, which were found to play a more significant role in causing abnormal behaviour in fraud detection than other features, were used to build their model.

Yang, et al. [58] proposed FraudMemory, a novel fraud detection algorithm that uses memory networks to improve performance and interpretability and captures sequential transaction patterns. The FraudMemory model has high adaptability to changes in fraud patterns and has a precision of 96.8%, a recall of 87.4% and an AUC of 0.969. This model also performed better than SVM, DNN, RF, and GRU methods.

Overall, xFraud [43] has difficulty detecting credit card fraud because of inconsistent patterns. The usual method is to monitor user behaviour through usage profiles, which is impractical due to many users. To address this limitation, most research has used deep anomaly detection methods. In telecommunications, the focus is on mobile networks and using GNNs to detect fraud is becoming popular due to its ability to understand complex relationships and make inferences from graph-based data.

¹² ResNet: Residual Network is a deep learning architecture that allows for training very deep neural networks with thousands of layers, while avoiding the problem of vanishing gradients.

4.4.2 Phishing

Mohammad, et al. [59] proposed a self-structuring neural network (NN) for detecting phishing website attacks. Their proposed model, the adaptive self-structuring NN, automates the network's structuring process by updating the learning rate and adding new neurons to the hidden layer. The goal of the model is to acquire generalisation ability. The model obtained an accuracy of 92.18%. The self-structuring nature of their model allows for robustness against distributional change, though not fully integrated, as the model must be retrained periodically.

Hernandes, et al. [60] used LIME and EBM¹³ interpretation techniques to evaluate the accuracy of RF, SVM, and EBM classifiers. The results showed that all three classifiers had high accuracy rates, with EBM having the highest at 96.46%.

4.5 Approaches' evaluation according to our criteria

The table below summarises the above-mentioned findings, according to the criteria selected in section II and per approach studied. For each approach, we evaluate whether they are adhering fully, partially or not at all, to the definitions we set forth in section II. These evaluations are conducted based on what the authors are stating in their approaches, and how they support their statements. The performance metrics are the ones provided by the authors of the considered articles: we did not run any benchmark nor test. For each metric and article, the maximum value available is reported in the Table 3.

Following the findings summed up in the table above, most approaches rely on numeric AI. Thus, the following section further discusses them, analysing their strengths, weaknesses, and potential shortcomings.

5 Analysis—overwhelming approaches of numeric AI for cybersecurity

In cybersecurity, the shift from symbolic AI to numeric AI has been driven by the need for faster, more flexible, and more scalable solutions. Numeric AI allows for real-time analysis and better adaptation to new threats, making it well-suited for cybersecurity's fast-paced and ever-evolving world. While symbolic AI has a rich history and has been used successfully in many applications [25], the growing demand for more powerful and efficient solutions has led to an increased focus on numeric AI in recent years.

5.1 Strengths

While numeric AI models can be computationally expensive to train, yielding significant investment in hardware and computational resources due to the large amounts of data they process, the benefits they deliver in terms of fast and accurate threat classification and response make them a valuable investment for organisations looking to protect themselves against cyber threats.

The studies referenced above have shown that numeric AI systems provide results with very high accuracy and precision in cybersecurity. The lowest accuracy found was 92.18% for phishing detection [59], with an average accuracy of 97.48%. Meanwhile, the lowest precision was 81.63% for DGA attacks [54], with an average precision of 93.82%. These results demonstrate the effectiveness of numeric AI in accurately and precisely detecting cyber threats.

Furthermore, it's worth noting that in 10 of the 21 studies, the accuracy and precision were at least 98%. It highlights the exceptional performance of numeric AI in detecting and preventing cyber threats.

The diversity of techniques and the large set of parameters used in numeric AI models enable them to address various use cases in multiple settings. This is particularly important in cybersecurity, where the threat landscape constantly evolves.

In the studies, botnets have many categories and subcategories, and numeric AI models can be trained and fine-tuned to detect and respond to these threats [49–52]. Similarly, malware families and variants are numerous, and numeric AI models can be used to classify and respond to these threats in real-time (less than a 1 μ s [47]) [44–46, 48].

¹³ EBM: Explainable Boosting Machine, an algorithm that generates human-understandable explanations of the model's decision-making process.

Table 3 Summary of approaches reviewed

Approach	Transparency	Justifiability	Interpretability	Suitability	Accuracy (max)	Precision (max)	Distributional change	Adversarial Inputs	Maintaining explainability	Symbolic	Numeric	Area	Attack
Explanatory pillars				Performance		Robustness		Types of AI					Cybersecurity
[49]	N	Y	Y	Y	97.90%	99.85%	N	N	N	N	Y	Application security	Botnet
[50]	N	Y	Y	Y	96.3%	U	N	N	N	N	Y	Application security	Botnet DGA-based
[51]	N	Y	Y	Y	99.76%	99.63%	Y	N	N	N	Y	Application security	Botnet
[52]	N	N	N	Y	99.99%	U	N	N	N	N	Y	Application security	Botnet
[53]	N	L	Y	Y	99.91%	81.73%	Y	Y	L	N	Y	Application security	DGA
[54]	N	Y	Y	Y	U	81.63%	N	N	Y	N	Y	Application security	DGA
[55]	N	N	N	Y	99.67% (1)	92.32%	N	N	N	N	Y	Application security	DGA
[38]	N	Y	Y	Y	97.23%	U	N	N	N	N	Y	Network security	DoS
[39]	N	L	L	Y	97.24%	92.20%	N	N	N	Y	Y	Network security	DoS
[44]	N	N	Y	Y	98.5%	96.9%	N	N	Y	Y	Y	Endpoint security	Malware
[45]	Y	Y	Y	Y	98.55%	97.93%	Y	N	Y	Y	Y	Endpoint security	Malware
[46]	N	Y	Y	L	97.0%	97.2%	N	N	N	N	Y	Endpoint security	Malware
[47]	N	Y	Y	Y	98.20%	98.54%	N	N	N	N	Y	Endpoint security	Malware
[48]	N	Y	Y	Y	98%	98%	N	N	N	N	Y	Endpoint security	Malware
[56]	N	Y	Y	Y	97.03%	96.13%	Y	N	Y	N	Y	User security	Fraud
[57]	N	Y	Y	Y	96.9%	83%	N	N	Y	N	Y	User security	Fraud
[58]	N	Y	Y	Y	96.9% (1)	96.8%	Y	N	Y	N	Y	User security	Fraud
[40]	N	Y	Y	Y	93.28%	91.05%	Y	Y	Y	N	Y	Network security	Network intrusion
[41]	N	Y	Y	Y	98.50%	98.22%	Y	Y	Y	N	Y	Network security	Network intrusion
[42]	N	Y	Y	Y	84% (1)	U	Y	N	Y	Y	Y	Network security	Network intrusion
[59]	N	N	N	Y	92.18%	U	L	N	N	N	Y	User security	Phishing
[60]	N	Y	Y	Y	96.46%	U	N	N	Y	N	Y	User security	Phishing

(1) AUC (Area Under the Receiver Operating Characteristic Curve)

Y = Yes | N = No | U = Unknown | L = Limited

Fraud schemes are also highly diverse, and numeric AI models can be used to detect and prevent fraudulent activities, such as credit card fraud or identity theft [56–58]. Network intrusions use many attack vectors and vulnerabilities, and numeric AI models can detect and respond to these threats, helping organisations prevent data breaches and other types of cyber-attacks [40, 41].

DGA is the backbone for many botnets and other swarm attacks, and numeric AI models can be used to detect and respond to these threats [53–55]. Phishing attacks have become increasingly sophisticated, and numeric AI models can detect and respond to them, helping organisations protect their employees and assets [59, 60].

DoS attacks may rely on a limited number of techniques but require fast and accurate action. Numeric AI models can detect and respond to these attacks, helping organisations prevent downtime and maintain the availability of their systems and services [38, 39].

The design of the systems in the studies is reported to be very high, with only one out of 21 having limited suitability [46]. This indicates that most systems analysed above have been well-designed and well-suited to their intended purpose.

High-quality design is fundamental in cybersecurity, as numeric AI systems are being used to detect and respond to a wide range of threats. If a system is poorly designed, it may be unable to detect and respond to these threats effectively, putting the security of organisations and their data at risk.

In summary, the results of these studies demonstrate that numeric AI systems are highly effective in accurately and precisely detecting and preventing cyber threats. The broad range of techniques and parameters used allows them to address a wide range of challenges. Furthermore, the high quality of the studied systems is an essential factor that helps to ensure their effectiveness.

Given their accuracy, precision, diversity, and high quality, numeric AIs are vital for organisations looking to improve their cybersecurity defences.

5.2 Weaknesses

The quality of available datasets used to train and test numeric AI systems significantly impacts the output quality [43]. This is particularly important in cybersecurity, as accurately classifying and responding to threats is critical.

While generative systems and other mitigation techniques are being used to address the limited quantity of data available, studies have shown that this remains a limiting factor in the models' confidence to address real-world, large-scale issues [43].

Another challenge with numeric AI systems is their lack of transparency. By nature, these systems are complex and operate in a black-box manner, making it difficult to understand how they make decisions: no study has been found even to attempt to provide transparency as defined in section II.A.1). In cybersecurity, this can be problematic as organisations need to have confidence in the systems used to protect themselves against cyber threats.

Explainability is another weakness of numeric AI systems. In all but 3 studies [39, 44, 45], interpretability is added post hoc, as the systems were not designed to be transparent from the outset. In a field such as cybersecurity, where the ability to understand and trust the decision-making process is critical, this is a significant weakness that needs to be addressed.

In summary, while numeric AI systems offer many benefits in cybersecurity, the limitations of available datasets and the lack of transparency and explainability remain challenges that must be addressed. Further research is needed to improve these systems' quality and reliability and ensure that they can be trusted to address real-world security challenges.

5.3 Shortcomings

Robustness is a critical aspect of numeric AI systems, particularly for cybersecurity, where the ability to respond to changing conditions and maintain accurate predictions is essential. However, few studies have addressed this issue.

Only eight studies address robustness against distributional changes, and only three focus on robustness against adversarial inputs [40, 41, 53]. Indeed, most numeric AI systems have not been tested or optimised to withstand changes in their operating environment, which can impact their performance and accuracy.

Regarding interpretations, some studies have added them post hoc, while most studies (10 out of 18) with some explainability level focus on maintaining it across changes, such as drift in the system's malicious or natural inputs.

Many authors acknowledge that real-world, large-scale applications of numeric AI systems in cybersecurity are rife with limitations. These include a lack of real-world testbeds [57], doubts about scalability [49], limited datasets in terms of quality, freshness, or quantity [43], and the need sometimes to retrain to adapt to changing conditions [50].

In summary, although numeric AI systems have the potential to improve cybersecurity significantly, the limited focus on robustness and the numerous challenges associated with real-world, large-scale implementation demonstrate the need for continued research and development in this field.

6 The road towards hybrid AI for cybersecurity—challenges and benefits

6.1 Hybrid AI definition

The term "hybrid AI" is often used in the literature to describe a mix of methods within the same group of AI. The concept of "neuro-symbolic" AI has also been intensively mentioned in recent years as an approach addressing the issue of having machines that do not just learn common sense but also understand it [61]. However, in the context of this paper, we use "hybrid AI" explicitly to refer to both symbolic and numeric AI methods to take advantage of the strengths of each approach and overcome their limitations.

Hybrid AI systems use symbolic and numeric AI methods to create a more robust and versatile AI system. Symbolic AI methods use logic and rules to formally represent knowledge and reason about it, making it possible to understand and explain the system's decisions. On the other hand, numeric AI methods use statistical and ML techniques to analyse large amounts of data and make predictions or decisions based on that analysis.

Additionally, the hybrid nature is considered even when one group of methods is used more heavily than the other. Even in cases where a system is primarily based on symbolic or numeric AI methods, integrating complementary methods from the other group is still considered hybrid AI. Regardless of their relative contributions to the system's performance, explainability, or robustness this approach is taken.

6.2 Expected benefits

One expected benefit of using hybrid AI in cybersecurity is that it should allow for the integration of multiple AI techniques, each with its strengths and weaknesses. For example, rule-based systems are great at identifying well-known threats using explainable mechanisms, but they are not very effective at massively processing potentially malicious data, nor can they be quickly adapted to new or unknown threats. While machine and deep learning algorithms can quickly process vast amounts of data and treat new or unknown threats quickly with unlabelled or partial data by analysing patterns, they are not as efficient at providing explainable feedback for their action or may not generalise as well as expected.

To the best of our knowledge, no current AI system in the cybersecurity domain provides complete, human-level natural language explanations of its decisions. Existing solutions typically rely on technical rule-based outputs or numeric feature importances, which may be comprehensible only to specialized analysts spending a fair amount of time on them. Introducing an automatically generated, natural language explanation of why a system has flagged a threat would enable any practitioners to more quickly trust and act upon the system's guidance. This accelerated comprehension could lead to swifter response times, faster prevention measures, and a more robust level of security overall.

In our first example, the approach chosen by Yan, et al. [45] is first to train a supervised DNN, therefore processing massive amounts of network traffic data, with the critical ability to retrain if and when needed on new data, updating the model to detect new threats or improve on detecting existing ones. The major shortcoming of such models is that their black-box nature hinders the analysis of malware discriminations made by the DNN. For this reason, Yan, et al. [45] extracted rules from the trained DNN layers to build a decision tree compact enough to be fully interpretable and embedded on an FPGA¹⁴ to detect malware behaviour on mobile devices.

The second example is a work by Himmelhuber, et al. [42] who proposed using a GNN that embeds a knowledge graph and then filters the security alerts raised by their anomaly detection system, reducing false alerts by 66%, thanks to the interpretation generated both from the GNN and the knowledge graph.

¹⁴ FPGA: Field Programmable Gate Array, a type of highly customisable and reconfigurable integrated circuit that can be programmed and configured by a user or designer after manufacturing.

6.3 Potential

Combining AI techniques in a hybrid AI system improves performance and adaptability to changing threat landscapes. Hybrid AI can benefit from the strengths of rule-based and ML algorithms to achieve higher accuracy and efficiency in detecting and preventing cyber threats. This makes it ideal for various cybersecurity applications, such as intrusion detection and prevention, malware detection, and threat hunting.

Additionally, the ability of hybrid AI systems to continue learning and adapting to new and evolving threats is a significant advantage over traditional rule-based systems, which rely on pre-defined rules that may become obsolete over time. With hybrid AI, the system can continuously update its understanding of the threat landscape and accordingly adjust its behaviour, making it a valuable tool in the fight against cybercrime.

Indeed, Yan, et al. [45] obtained a decision tree built upon a trained DNN that is transparent, justifiable, and interpretable. Nonetheless, their system performed exceptionally well compared to other state-of-the-art malware detection approaches regarding accuracy, precision, recall, and F-Measure. Moreover, the lightweight nature of their model makes it incredibly fast and more scalable.

Also, Himmelhuber, et al. [42] provide interpretations without transparency by using explainable AI frameworks (GNNExplainer and DL-Learner) and use knowledge graphs to train their GNN and filter out a large part of the false alerts.

7 Conclusions

As the above review proves, combining numeric and symbolic AI approaches can only enhance the performances achieved so far when using only numeric AI systems. Still, the journey towards attaining such a combination comes with several challenges. These challenges are to be addressed soon, especially given the evolution of the regulatory context with initiatives such as the EU AIA and its specific articles pointing to High-Risk AI Systems, with a later entry into force by mid-2026 [26].

Coupled with the regulatory context, the increasing number of connected devices (expected to generate 79 zettabytes of data by 2025 [32], a first challenge for hybrid AI relates to data integration, knowledge representation and rule-based reasoning. These relate to the hybrid AI system's symbolic component, which is less addressed in existing research (as demonstrated above). Recent approaches such as Piplai, et al. [62] have discussed the issue of combining (e.g., network logs, threat intelligence feeds) with unstructured data (e.g., incident reports or security policies) into knowledge bases that can serve neuro-symbolic AI. The latter has also been identified as critical by Ghosh [63] for providing comprehensive and robust user analytics in cybersecurity. Creating a cohesive framework for representing numeric patterns and symbolic rules would allow seamless interaction between the two AI paradigms and, thus, explainable AI for security decision-making. The symbolic part enables the modelling of human-understandable rules. It provides logical (therefore clear) explanations for the AI system's decisions, hence a high level of explainability and transparency, which we identified as crucial for ensuring trust and accountability in cybersecurity.

Another challenge for hybrid AI addresses the management of computation complexity. As discussed in earlier sections, numeric AI-based approaches have demonstrated performances in terms of scalability and efficiency in handling large-scale cybersecurity data. Finding the correct balance between the resource-intensive nature of deep learning and the complexities of symbolic AI's rule-based reasoning would allow almost real-time threat detection and explainable decision-support. Still, developing the underlying algorithms and architectures that enable the hybrid processing of vast data remains an active challenge [64].

Finally, ensuring such hybrid AI systems' adaptability and continuous learning is the ultimate challenge. Tackling it would allow the reuse of the explainable and efficient hybrid AI solutions developed for handling evolving threats, as common in the rapidly changing cybersecurity landscape. With such real-time updates of the numeric and symbolic components, hybrid AI systems could detect and reason about new threats that fell outside their previous knowledge base.

In conclusion, hybrid AI allows for integrating different representation and reasoning methods, such as rule-based reasoning, decision trees, and neural networks, to create a more versatile and adaptive AI system. This can lead to significant improvements in performance, robustness, and scalability, as well as an increase in explainability and

transparency of the decisions made by the AI system. These advantages make hybrid AI attractive for organisations looking to enhance their cybersecurity defences. By addressing the different challenges discussed in this article, organisations can harness the full potential of hybrid AI to enhance their cybersecurity posture, combining numeric AI's pattern recognition capabilities with symbolic AI's reasoning and explainability. Furthermore, practitioners need to adopt urgent measures for industry adoption, such as cross-referencing global frameworks (e.g., NIST, ENISA) alongside recent approaches by Radanliev et al. [65, 66], embedding ethical-by-design checks from the outset, and implementing shared auditing tools for real-time adversarial and explanation testing. Embracing these steps across multiple standards and contexts will help foster greater trust, resilience, and ethical usage of AI-driven cybersecurity solutions worldwide.

Acknowledgements We want to thank the Faculty of Science and Technology at the Université de Bourgogne Europe for their academic assistance and to the anonymous reviewers for their valuable feedback.

Author contributions SR has gathered the review raw material. AR has provided methodology to the approach, structure of the article and mentoring. Both authors have contributed equally to all other aspects. All authors read and approved the final manuscript.

Funding This review was done without any source of funding.

Declarations

Data availability No datasets were generated or analysed during the current study.

Ethics approval and consent to participate Not applicable.

Consent for publication Not applicable.

Competing interests The authors declare no competing interests.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

1. ITU-T. Recommendation X.1205: Overview of cybersecurity, Telecommunication standardization sector of ITU, 2008.
2. Hylender CD, Langlois P, Pinto A, Widup S. 2023 Data Breach Investigations Report. 2023.. Available: <https://www.verizon.com/business/resources/reports/2023-data-breach-investigations-report-dbir.pdf>. Accessed 25 Aug 2023.
3. Filippis AD. French cloud services saw cyberattacks increase by 630% in 2020. 7 January 2022. Available: <https://www.euronews.com/my-europe/2022/01/07/french-cloud-services-saw-cyberattacks-increase-by-630-in-2020>. Accessed 25 Aug 2023.
4. Raj A. Gaining privileged access still the main target for cyber attackers. 28 July 2022. [Online]. Available: <https://techwireasia.com/2022/07/gaining-privileged-access-still-the-main-target-for-cyber-attackers/>. Accessed 25 Aug 2023.
5. Schatz D, Bashroush R, Wall J. Towards a more representative definition of cyber security. *J Digital Foren Secur Law*. 2017;12(2):53–74.
6. Parisi A. Hands-on artificial intelligence for cybersecurity, Packt, 2019.
7. Srivastava G, Jhaveri RH, Bhattacharya S, Pandya S, Rajeswari C, Maddikunta PKR, Yenduri G, Hall JG, Alazab M, Gadekallu TR. XAI for cybersecurity: state of the art, challenges, open issues and future directions. *ACM Comput Surv*. 12022; 1.
8. Flasiński M. Introduction to artificial intelligence. Berlin: Springer; 2016. p. 3–27.
9. Honavar V. Symbolic artificial intelligence and numeric artificial neural networks: towards a resolution of the dichotomy. In: *Computational architectures integrating neural and symbolic processes*, Kluwer Academic Publishers, 1995, pp. 375–377.
10. McCarthy J. Programs with common sense. In: *Teddington Conference on the Mechanization of Thought Processes*. 1958.
11. Newell A, Simon H. Computer science as empirical inquiry: symbols and search. *Commun ACM*. 1976;19(3):113–29.
12. McBride T, Ekstrom M, Lusty L, Sexton J, Townsend A. Data integrity: recovering from ransomware and other destructive events, 2020.
13. Gunning D, Stefik M, Choi J, Miller T, Stumpf S, Yang G-Z. XAI—explainable artificial intelligence. *Sci Robot*. 2019;4:37.
14. Ciatto G, Calvaresi D, Schumacher M, Omicini A. An abstract framework for agent-based explanations in AI. In: *Proceedings of the International Conference on Autonomous Agents and Multi-Agent Systems*, Auckland, New Zealand, 2020.
15. Miller T. Explanation in artificial intelligence: insights from the social sciences. *Artif Intell*. 2019;267:1–38.

16. Gilpin LH, Bau D, Yuan BZ, Bajwa A, Specter M, Kagal L. Explaining explanations: an overview of interpretability of machine learning. In: IEEE 5th International Conference on Data Science and Advanced Analytics (DSAA), Turin, Italy, 2018.
17. Phillips PJ, Hahn CA, Fontana PC, Yates AN, Greene K, Broniatowski DA, Przybocki MA. Four principles of explainable artificial intelligence. National Institute of Standards and Technology, 2021.
18. Biran O, Cotton C. Explanation and justification in machine learning: a survey. In: IJCAI-Workshop on explainable AI (XAI), Melbourne, Australia, 2017.
19. Montavon G, Samek W, Müller K-R. Methods for interpreting and understanding deep neural networks. *Digital Signal Process.* 2018;73:1–15.
20. Calegari R, Ciatto G, Omicini A. On the integration of symbolic and sub-symbolic techniques for XAI: a survey. *Intell Artif.* 2020;14(1):7–32.
21. Russell S, Norvig P. Trust, interpretability, and explainability. In: *Artificial intelligence: a modern approach*. Pearson, 2022, p. 710.
22. Ribeiro MT, Singh S, Guestrin C. Why Should I Trust You?": explaining the predictions of any classifier. In: 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, New York, NY, USA, 2016.
23. Barredo Arrieta A, Díaz-Rodríguez N, DelSer J, Bennetot A, Tabik S, Barbado A, Garcia S, Gil-Lopez S, Molina D, Benjamins R, Chatila R, Herrera F. Explainable artificial intelligence (XAI): concepts, taxonomies, opportunities and challenges toward responsible AI. *Inf Fusion.* 2020;58:82–115.
24. Russell S, Norvig O. Trust and transparency. In: *Artificial intelligence: a modern approach*, Pearson, 2022, p. 996.
25. Swartout WR, Moore JD. Explanation in second generation expert systems. In: *Second generation expert systems*. Berlin: Springer; 1993. p. 543–85.
26. The European Union, Artificial Intelligence Act, 2024.
27. Lundberg SM, Lee S-I. A unified approach to interpreting model predictions. In: 31st International Conference on Neural Information Processing Systems, Red Hook, NY, USA, 2017.
28. Rida AA, Amhaz R, Parrend P. Metrics for evaluating interface explainability models for cyberattack detection in IoT data. In: *Complex computational ecosystems*, Cham, 2023.
29. ISO/IEC TS. Systems and software Quality Requirements and Evaluation (SQuaRE) — Service quality models, The International Organization for Standardization and the International Electrotechnical Commission), 2017.
30. ISO. Accuracy (trueness and precision) of measurement methods and results, The International Organization for Standardization, 1998.
31. Chu Dieu L. The Role of AI in Cybersecurity Protecting Against Evolving Threats. 2024. Available: <https://smartdev.com/the-role-of-ai-in-cybersecurity-protecting-against-evolving-threats/>. Accessed 18 Dec 2024.
32. Shutenko V. AI in Cybersecurity: Exploring the Top 6 Use Cases. 2024. Available: <https://www.techmagic.co/blog/ai-in-cybersecurity/>. Accessed 18 Dec 2024.
33. Palo Alto Networks. What is precision AI? 2024. Available: <https://www.paloaltonetworks.com/cyberpedia/what-is-precision-ai>. Accessed 18 Dec 2024.
34. Smith AL, Clifford R. Quality characteristics of artificially intelligent systems. In: *Experience with SQuaRE Series and Its Future Direction*, Singapore, 2020.
35. Azhand A. AI model robustness: a new frontier in cybersecurity. 2024. Available: <https://applydata.io/ai-model-robustness-a-new-frontier-in-cybersecurity/>. Accessed 18 Dec 2024.
36. Polito C, Pupillo L. Artificial intelligence and cybersecurity. *Intereconomics.* 2024;59:10–3.
37. Nolte H, Rateike M, Finck M. Robustness and cybersecurity in the EU artificial intelligence act. 2024.
38. Amarasinghe K, Kenney K, Manic M. Toward explainable deep neural network based anomaly detection. In: 11th International Conference on Human System Interaction (HSI), Gdansk, Poland, 2018.
39. Amor NB, Benferhat S, Elouedi Z. Naive Bayes vs decision trees in intrusion detection systems. In: *ACM Symposium on Applied Computing (SAC)*, New York, USA, 2004.
40. Barnard P, Marchetti N, DaSilva LA. Robust network intrusion detection through explainable artificial intelligence (XAI). *IEEE Netw Lett.* 2022;4(3):167–71.
41. Wali S, Khan I. Explainable AI and random forest based reliable intrusion detection system. *TechRxiv*, Preprint, 2021.
42. Himmelhuber A, Dold D, Grimm S, Zillner S, Runkler T. Detection, explanation and filtering of cyber attacks combining symbolic and sub-symbolic methods, *IEEE*, 2022.
43. Macas M, Wu C, Fuertes W. A survey on deep learning for cybersecurity—progress, challenges, and opportunities. *Comput Netw.* 2022;212: 109032.
44. Naeem H, Alshammari BM, Ullah F. Explainable artificial intelligence-based IoT device malware detection mechanism using image visualization and fine-tuned CNN-based transfer learning model. *Comput Intell Neurosci.* 2022;2022:1–17.
45. Yan A, Chen Z, Zhang H, Peng L, Yan Q, Hassan MU, Zhao C, Yang B. Effective detection of mobile malware behavior based on explainable deep neural network. *Neurocomputing.* 2021;453:482–92.
46. Iadarola G, Martinelli F, Mercaldo F, Santone A. Towards an interpretable deep learning model for mobile malware detection and family identification. *Comput Secur.* 2021;105: 102198.
47. Alani MM, Awad AI. PAIRED: an explainable lightweight android malware detection system. *IEEE Access.* 2022;10:73214–28.
48. Kinkead M, Millar S, McLaughlin N, O’Kane P. Towards explainable CNNs for android malware detection. In: *International Symposium on Machine Learning and Big Data Analytics For Cybersecurity and Privacy (MLBDACP)*, Warsaw, Poland, 2021.
49. Kundu PP, Truong-Huu T, Chen L, Zhou L, Teo SG. Detection and classification of botnet traffic using deep learning with model explanation. In: *IEEE Transactions on Dependable and Secure Computing*, pp. 1–15, 2022.
50. Suryotrisongko H, Musashi Y, Tsuneda A, Sugitani K. Robust botnet DGA detection: blending XAI and OSINT for cyber threat intelligence sharing. *IEEE Access.* 2022;10:34613–24.
51. Alani MM. BotStop: packet-based efficient and explainable IoT botnet detection using machine learning. *Comput Commun.* 2022;193:53–62.
52. McDermott CD, Majdani F, Petrovski AV. Botnet detection in the internet of things using deep learning approaches. In: *International Joint Conference on Neural Networks (IJCNN)*, Rio de Janeiro, Brazil, 2018.

53. Drichel A, Meyer U, Schüppen S, Teubert D. Analyzing the real-world applicability of DGA classifiers. In: The 15th International Conference on Availability, Reliability and Security, ACM, New York, USA, 2020.
54. Drichel A, Faerber N, Meyer U. First Step Towards EXPLAINable DGA Multiclass Classification. In: The 16th International Conference on Availability, Reliability and Security, ACM, New York, USA, 2021.
55. Mac H, Tran D, Tong V, Nguyen LG, Tran HA. DGA botnet detection using supervised learning methods. In: Proceedings of the 8th International Symposium on Information and Communication Technology (SolCT), New York, USA, 2017.
56. Rao SX, Zhang S, Han Z, Zhang Z, Min W, Chen Z, Shan Y, Zhao Y, Zhang C. xFraud: explainable fraud transaction detection. Very Large Data Bases, Sydney, Australia, 2022.
57. Roshan K, Zafar A. Utilizing XAI technique to improve autoencoder based model for computer network anomaly detection with Shapley additive explanation (SHAP). *Int J Comput Netw Commun (IJCNC)*. 2021;13(6):109.
58. Yang K, Xu W. FraudMemory: explainable memory-enhanced sequential neural networks for financial fraud detection. In: Hawaii International Conference on System Sciences, Monoa, 2019.
59. Mohammad RM, Thabtah F, McCluskey L. Predicting phishing websites based on self-structuring neural network. *Neural Comput Appl*. 2014;25:443–58.
60. Hernandez PRG, Floret CP, Almeida KFCD, Silva VCD, Papa JP, Costa KAPD. Phishing detection using URL-based XAI techniques. In: IEEE Symposium Series on Computational Intelligence (SSCI), Orlando, FL, USA, 2022.
61. Dingli A, Farrugia D. Neuro-symbolic AI. PackT Publishing. 2023.
62. Piplai A, Kotal A, Gaur MSM, Mittal S, Joshi A. Knowledge-enhanced neuro-symbolic AI for cybersecurity and privacy. *IEEE Internet Comput*. 2023;27:43.
63. Ghosh S. From Petabytes to Peace of Mind: LLM & Graphs for Neuro-Symbolic AI Security on GCP. 2024. Available: <https://www.innovasolutions.com/blogs/from-petabytes-to-peace-of-mind-llm-graphs-for-neuro-symbolic-ai-security-on-gcp/>. Accessed 18 Dec 2024.
64. Sentinel One. Top 6 Hybrid Cloud Security Challenges. 2024. [Online]. Available: <https://www.sentinelone.com/cybersecurity-101/cloud-security/hybrid-cloud-security-challenges/>. Accessed 18 Dec 2024.
65. Radanliev P, Santos O, Brandon-Jones A, Joinson A. Ethics and responsible AI deployment. *Front Artif Intell*. 2024. <https://doi.org/10.3389/frai.2024.1377011>.
66. Radanliev P. AI ethics: integrating transparency, fairness, and privacy in AI development. *Appl Artif Intell*. 2025. <https://doi.org/10.1080/08839514.2025.2463722>.

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.